

TERO Security

Plataforma de ciberseguridad defensiva para empresas

DOCUMENTO DE ANÁLISIS FUNCIONAL

Versión 1.1 · Octubre 2026

tecnoros.ar · Rosario, Argentina

WhatsApp 11 2507-9568 · 341 313-0336 · tecnorosar@gmail.com

Contenido

1. Resumen
2. Alcance
3. Usuarios y roles
4. Módulos funcionales
5. Flujo principal
6. Arquitectura
7. Requisitos
8. Cómo se instala y se levanta
9. Primeros pasos de uso
10. Seguridad y modo simulación
11. Licencia y abono mensual
12. Operación y mantenimiento
13. Problemas frecuentes
14. Video demostrativo
15. Glosario

1. Resumen

TERO Security es una plataforma de ciberseguridad **defensiva** que reúne en un solo lugar lo que una empresa necesita para conocer sus riesgos y responder a los ataques: inventario de equipos, escaneo de vulnerabilidades, detección de amenazas en tiempo real (SIEM), respuesta automática (SOAR), gestión de incidentes, medición de cobertura contra técnicas de ataque y reportes para la dirección.

Está pensada para **pymes y empresas** que no tienen un equipo de seguridad grande: la interfaz está en español, incluye una guía paso a paso y todas las acciones que podrían afectar la infraestructura arrancan en **modo simulación**.

Se instala en la red del cliente (on-premise) con Docker, y se comercializa como **abono mensual** con licencia por organización.

2. Alcance

Incluye

- Inventario de activos (CMDB).
- Escaneo de vulnerabilidades en modo detección (Nuclei, Trivy, ZAP, Semgrep, Gitleaks, YARA, Zeek, Falco).
- Priorización con CVSS, EPSS y catálogo CISA KEV.
- Monitoreo de la superficie expuesta en internet, nube AWS y repositorios de código.
- SIEM con reglas Sigma e inteligencia de amenazas.

No incluye (por diseño)

- Herramientas de ataque, explotación o frameworks de comando y control (C2).
- Ejecución real de técnicas ofensivas: el módulo purple team analiza datos declarados, nunca ataca.
- Cambios en la infraestructura del cliente sin autorización explícita (todo arranca en modo simulación).

- SOAR con playbooks de respuesta.
- Gestión de casos con SLA y línea de tiempo.
- Cobertura MITRE ATT&CK (purple team).
- Reportes en PDF/CSV, notificaciones e integraciones.
- Multi-empresa (multi-tenant), SSO y MFA.

> TERO Security **detecta y responde**, nunca ataca. Los escaneos buscan fallas sin explotarlas ni dañar los equipos.

3. Usuarios y roles

Rol	Qué puede hacer
Administrador de plataforma	Administra toda la instalación: crea organizaciones (empresas cliente), configura el SSO de cualquiera y gestiona licencias y pagos. El primer usuario registrado recibe este rol automáticamente.
Administrador de organización	Administra su propia empresa: usuarios, inicio de sesión único (SSO), conectores, agentes de escaneo y facturación.
Responsable del SOC	Opera todo el centro de seguridad: escaneos, casos, playbooks de respuesta y reportes.
Analista	Trabaja el día a día: revisa vulnerabilidades y alertas, gestiona casos, lanza escaneos y genera reportes.
Lector	Solo lectura: ve todo el sistema pero no ejecuta ni modifica nada. Ideal para la gerencia o para una demo. Es el rol que recibe quien se registra solo.

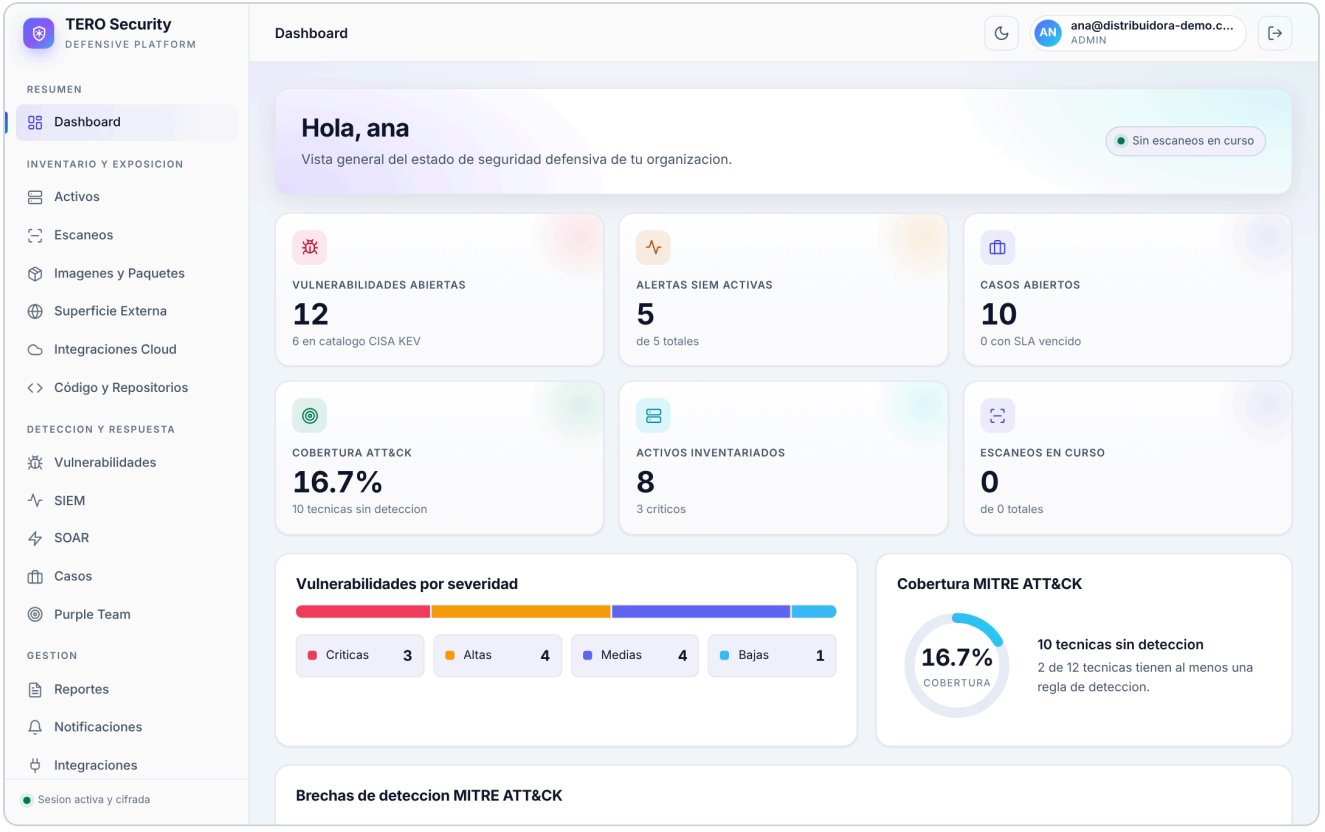
Aislamiento entre empresas: cada organización solo ve sus propios datos (activos, alertas, casos, reportes, etc.). Un usuario nunca puede ver información de otra empresa.

Ingreso: usuario y contraseña, doble factor (MFA con app tipo Google Authenticator), cuenta de Google o SSO empresarial (Microsoft Entra ID, Okta, Google Workspace, Keycloak, Auth0 y cualquier proveedor OIDC).

4. Módulos funcionales

Módulo	Qué hace
Dashboard	Vista general: vulnerabilidades abiertas, alertas activas, casos y SLA vencidos, cobertura ATT&CK, activos críticos, escaneos en curso, últimas respuestas automáticas y avisos enviados.
Activos	Inventario de servidores, computadoras y equipos con IP, sistema operativo, entorno, criticidad y responsable. Desde cada activo se lanza un escaneo.
Escaneos	Escaneos de detección por IP, rango o dominio; análisis de imágenes de contenedor y archivos de dependencias; análisis de archivos sospechosos con YARA; escaneos programados (diarios o semanales); agentes remotos para escanear la red interna de la oficina.
Imágenes y paquetes	Inventario de imágenes y sistemas de archivos escaneados con sus paquetes y vulnerabilidades por gravedad.
Superficie externa	Monitorea los dominios de la empresa: descubre subdominios publicados en internet y certificados, y avisa cuando aparece algo nuevo.
Integraciones cloud	Se conecta a AWS con permisos de solo lectura, inventaría recursos (EC2, grupos de seguridad, buckets S3) y detecta configuraciones peligrosas, como buckets públicos o puertos abiertos a todo internet.
Código y repositorios	Escanea repositorios de código en busca de contraseñas o claves olvidadas y de dependencias vulnerables. Las claves encontradas se muestran ocultas.
Vulnerabilidades	Lista unificada de hallazgos con puntaje de prioridad (CVSS, EPSS, CISA KEV), filtros, pasos de remediación sugeridos y triage: confirmar, falso positivo, aceptar riesgo o marcar como remediada.
SIEM	Recibe logs, los normaliza y aplica reglas Sigma para generar alertas. Consulta la reputación de IPs en fuentes de inteligencia de amenazas (AbuseIPDB / MISP).
SOAR	Playbooks de respuesta automática: bloquear IP, aislar equipo, abrir caso, crear ticket, notificar. Se disparan por severidad o etiqueta de regla, o a mano.
Casos	Gestión de incidentes estilo mesa de ayuda: prioridad, responsable, estado, SLA y línea de tiempo de auditoría. Se crean solos desde SOAR o a mano.
Purple Team	Mide qué técnicas de ataque MITRE ATT&CK quedan cubiertas por las reglas de detección y muestra las brechas. Permite declarar ejercicios y calcular su cobertura.
Reportes	Resumen ejecutivo, vulnerabilidades, incidentes y cobertura ATT&CK, exportables a PDF o CSV. Se pueden programar para que lleguen por email.

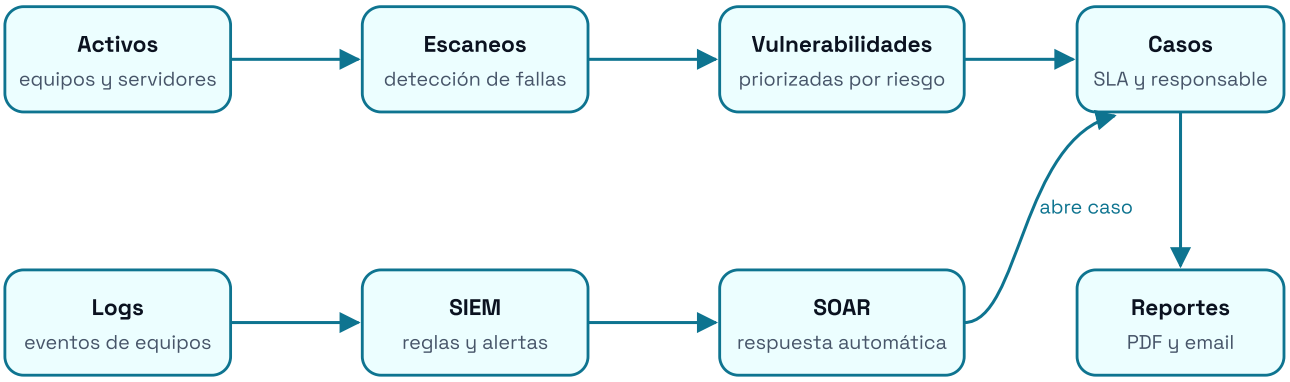
Notificaciones	Canales de aviso por email y Slack (webhook), con historial de envíos y envío de prueba.
Integraciones	Conectores con firewall, EDR/NAC y mesa de ayuda (por ejemplo Jira), con historial de acciones de contención y tickets creados.
Organizaciones	Alta de empresas cliente con su primer administrador y configuración de SSO.
Usuarios	Alta de usuarios de la organización con su rol, activación y desactivación, y doble factor por usuario.
Seguridad de la cuenta	Cada persona activa su doble factor (MFA) escaneando un código QR con su app de autenticación.
Pagos y licencia	Estado del abono de cada organización, pago con Mercado Pago o PayPal, historial y cancelación.
Ayuda	Guía interactiva en español, por sección, con progreso de lectura.



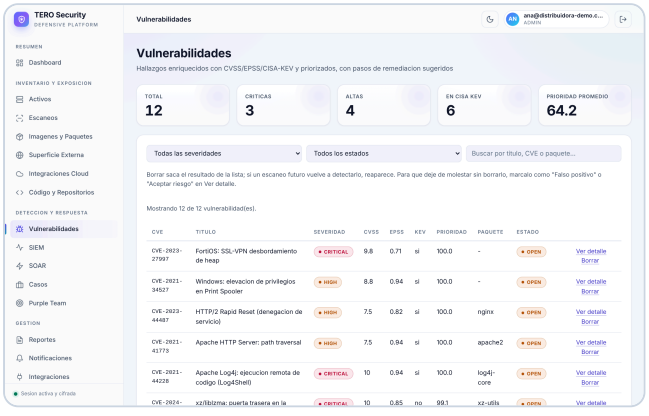
Dashboard con datos de demostración de una empresa ficticia.

5. Flujo principal

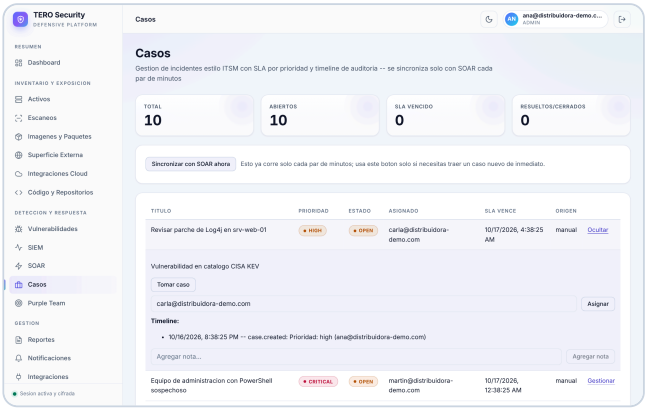
Así trabajan los módulos juntos, desde que se registra un equipo hasta que la dirección recibe el reporte:



1. Se registran los **activos** y se lanzan **escaneos** (a mano o programados).
2. Los hallazgos llegan a **Vulnerabilidades**, ordenados por riesgo real, con los pasos para corregirlos.
3. En paralelo, el **SIEM** analiza los logs y genera **alertas** cuando una regla coincide.
4. Según la gravedad, el **SOAR** ejecuta un playbook: bloquea la IP, aísla el equipo, notifica y abre un **caso**.
5. El equipo gestiona el caso hasta resolverlo, dentro del SLA, y todo queda en la línea de tiempo.
6. **Reportes** y **Purple Team** muestran la evolución y las brechas de detección para tomar decisiones.



Vulnerabilidades priorizadas.



Caso con su línea de tiempo.

6. Arquitectura

TERO Security está formado por **15 microservicios** (Python/FastAPI) y una aplicación web (React + TypeScript), orquestados con Docker Compose. Los datos se guardan en **PostgreSQL**, los logs en **OpenSearch** y **Redis** se usa para sesiones y límites de intentos. Los servicios se comunican por HTTP con tokens de corta duración.

Servicio	Puerto	Función
auth-service	8001	Identidad, sesiones, MFA, roles, organizaciones, SSO y licencias
asset-service	8002	Inventario de activos
scan-service	8003	Orquestación de escáneres y agentes remotos
vuln-service	8004	Priorización y triage de vulnerabilidades
siem-service	8005	Ingesta de logs, reglas Sigma y alertas
soar-service	8006	Playbooks de respuesta
case-service	8007	Casos, SLA y línea de tiempo
purple-service	8008	Cobertura MITRE ATT&CK
report-service	8009	Reportes y envíos programados
notification-service	8010	Email y Slack
integration-service	8011	Firewall, EDR y ticketing
threatintel-service	8012	Reputación de IPs
asm-service	8013	Superficie externa
cloud-service	8014	Nube AWS
coderepo-service	8015	Repositorios de código
frontend	5173	Aplicación web (dashboard)

Por seguridad, los puertos se publican solo en la propia PC (`127.0.0.1`). Para usar TERO Security desde otras computadoras de la red se recomienda un proxy con HTTPS.

7. Requisitos

Requisito	Detalle
Sistema operativo	Windows 10/11, macOS o Linux.
Docker	Docker Desktop (Windows/Mac) o Docker Engine con Docker Compose (Linux). Es obligatorio.
Hardware recomendado	16 GB de RAM, 4 núcleos y 30 GB libres en disco (estimación: corren unos 20 contenedores, incluido OpenSearch).
Navegador	Chrome, Edge o Firefox actualizados.
Red	Salida a internet para descargar imágenes, actualizar bases de vulnerabilidades y, si se usa, validar la licencia.
Opcional	Cuenta SMTP para emails, webhook de Slack, credenciales de lectura de AWS, token de repositorios, cuenta de Jira, proveedor SSO.

8. Cómo se instala y se levanta

Opción A: Windows, sin línea de comandos

1. Instalar **Docker Desktop** y abrirlo.
2. Descomprimir la carpeta de TERO Security que entrega tecnoros.ar.
3. Doble clic en **TERO Security - Iniciar.exe**. Verifica Docker, crea la configuración la primera vez, levanta todos los servicios, espera a que respondan y abre el dashboard en el navegador.
4. Para apagar: **TERO Security - Detener.exe**. No borra los datos.

> Si algún servicio no responde a tiempo, el iniciador muestra su registro (log) para poder diagnosticarlo sin abrir una terminal.

Opción B: línea de comandos (Windows, Mac o Linux)

```
# 1. Crear la configuración a partir del ejemplo
cp .env.example .env
#    Completar POSTGRES_PASSWORD y JWT_SECRET_KEY con valores propios y seguros

# 2. Levantar todo
make up            # equivale a: docker compose up --build -d

# 3. Ver los registros
make logs

# 4. Apagar (conserva los datos)
make down
```

Verificar que levantó

Cada servicio responde en `/health`. Ejemplo:

```
for port in 8001 8002 8003 8004 8005 8006 8007 8008 8009 8010 8011; do
  echo "puerto $port: $(curl -s -o /dev/null -w '%{http_code}'
http://localhost:$port/health)"
done
```

Después, abrir **http://localhost:5173** en el navegador.

Primer ingreso

1. En la pantalla de ingreso elegir **"Creala con tu email"** y registrar el primer usuario.
2. Ese primer usuario queda como **administrador de plataforma** automáticamente.
3. Los siguientes usuarios entran como **analistas**. El administrador puede crear organizaciones y su administrador desde **Organizaciones**.

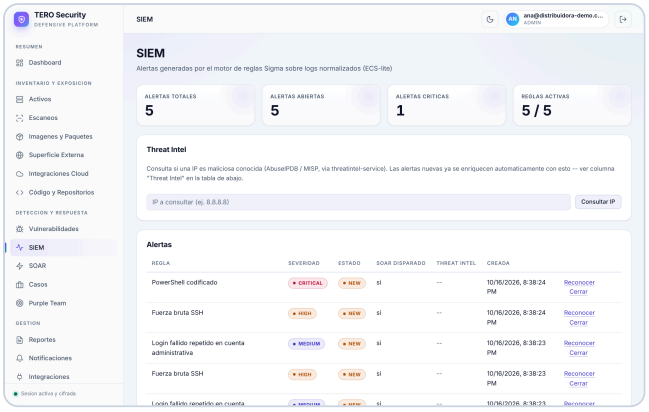
4. Recomendado: activar **MFA** para los administradores.

Configuraciones opcionales

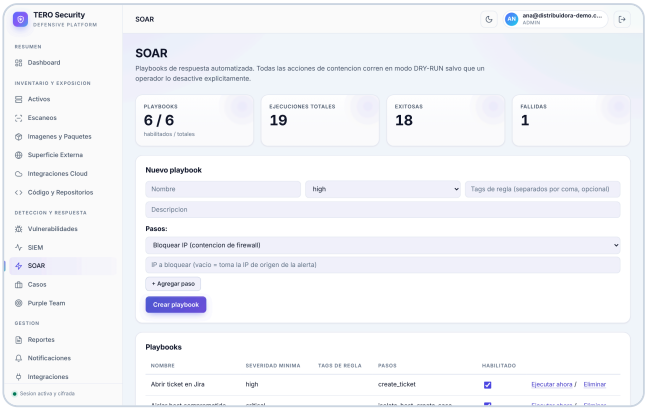
Función	Qué configurar
Ingreso con Google	`GOOGLE_CLIENT_ID` y `VITE_GOOGLE_CLIENT_ID` en el `.env`.
SSO empresarial	Organizaciones → Configurar SSO: issuer, client ID, client secret y rol por defecto.
Emails	`SMTP_HOST`, `SMTP_PORT`, `SMTP_USER`, `SMTP_PASSWORD`, `SMTP_FROM`.
Escaneo de la red interna	Escaneos → Agentes de escaneo remoto → Registrar agente, y correr el agente en una PC de esa red con `AGENT_API_KEY` y `SCAN_SERVICE_URL`. Hay tres tipos: Agente Docker (internet y la propia PC), Agente LAN (instalador de un paso para Windows, para la red de la oficina) y Agente WAN (equipos expuestos a internet).
Licencia	`LICENSE_SERVER_URL` y `LICENSE_KEY` que entrega tecnoros.ar.

9. Primeros pasos de uso

1. **Registrar activos:** Activos → cargar servidores y computadoras con su criticidad.
2. **Lanzar un escaneo:** desde el activo ("Escanear") o desde Escaneos, con una IP, rango o dominio.
3. **Revisar vulnerabilidades:** empezar por las de mayor prioridad y las marcadas en CISA KEV; abrir "Ver detalle" para ver cómo corregirlas.
4. **Cargar reglas de detección:** SIEM → "Cargar reglas recomendadas".
5. **Revisar los playbooks:** SOAR → habilitar los que correspondan (arrancan en modo simulación).
6. **Configurar avisos:** Notificaciones → agregar email o Slack.
7. **Seguir los casos** hasta resolverlos y **programar el reporte ejecutivo** semanal.
8. **Agregar dominios** en Superficie externa y, si aplica, la cuenta de AWS y los repositorios.



SIEM: alertas con inteligencia de amenazas.



SOAR: playbooks y ejecuciones.

10. Seguridad y modo simulación

Por defecto TERO Security **no toca la infraestructura real**: las acciones de bloqueo, aislamiento y los envíos quedan registrados como **simulados**. Para pasar a acciones reales, y solo si el cliente lo pide y entiende las consecuencias:

1. **Notificaciones reales:** configurar el canal y poner `NOTIFICATION_DRY_RUN=false`.
2. **Contención real:** configurar el conector de firewall o EDR y poner `INTEGRATION_DRY_RUN=false`.
3. Recién después, `SOAR_DRY_RUN=false` para que los playbooks actúen de verdad.

Volver cualquiera de esos valores a `true` regresa de inmediato al modo seguro.

Medidas incluidas

- Contraseñas con bcrypt, sesiones con JWT de corta duración y renovación automática, MFA opcional.

- Aislamiento total de datos entre organizaciones.
- Auditoría: línea de tiempo de casos y registro de acciones.
- Contenedores con privilegios mínimos y puertos solo en la PC local.
- Protección contra pedidos a la red interna (SSRF): no se puede escanear ni conectar la propia plataforma, direcciones privadas ni metadatos de la nube.
- Calidad verificada (octubre 2026): 820 pruebas automáticas en verde, 50 pruebas de punta a punta sobre los 15 servicios y las 20 pantallas revisadas sin errores.
- Agentes remotos con clave propia, sin abrir puertos de entrada en la red del cliente.
- Controles automáticos de seguridad del código (análisis de dependencias, secretos y contenedores).

11. Licencia y abono mensual

TERO Security se contrata como **abono mensual por organización**. Cada instalación valida periódicamente su licencia contra el servidor de licencias de tecnoros.ar, con respuestas firmadas digitalmente. Si una instalación queda demasiado tiempo sin poder validarla, se bloquea hasta regularizar.

Desde **Pagos y licencia** el administrador ve hasta cuándo está pago el abono, obtiene el link de pago, consulta el historial y puede cancelar.

Medios de pago: Mercado Pago (tarjeta de crédito o débito, o dinero en cuenta de Mercado Pago / Mercado Libre) o PayPal (tarjeta internacional o saldo PayPal).

> Precio: abono mensual a consultar. Escribinos por WhatsApp al 11 2507-9568 o al 341 313-0336.

12. Operación y mantenimiento

Tarea	Cómo
Copias de seguridad	PostgreSQL guarda casi todo: hacer `pg_dump` periódico. Definir retención para los logs de OpenSearch.
Actualizar	Reemplazar la carpeta por la versión nueva conservando el `.env` y volver a correr `make up` o el iniciador.
Cambiar claves	Rotar periódicamente la clave de sesiones (JWT), la contraseña de la base y las claves de agentes con la herramienta de rotación incluida.
Escalar	Los servicios no guardan estado propio, así que se pueden replicar (por ejemplo, en Kubernetes).
Monitorear	Revisar `/health` de cada servicio y que Redis esté funcionando.

13. Problemas frecuentes

Síntoma	Causa y solución
Un servicio no arranca	Revisar `docker compose logs <servicio>`. Suele ser que PostgreSQL u OpenSearch tardan en iniciar: esperar y reintentar.
El escaneo de la red interna no encuentra nada	Docker Desktop aísla los contenedores de la red de la oficina. Usar un **agente remoto** en una PC de esa red.
"SCANNER_UNAVAILABLE"	Falta el escáner en la imagen o el objetivo no corresponde: Trivy espera una imagen o carpeta, Nuclei un host o URL.
Una regla no genera alertas	Verificar que la regla esté habilitada y que su condición use selecciones definidas.
Cobertura ATT&CK en 0%	El SIEM no responde o las reglas no tienen etiquetas `attack.tXXXX`.
Los emails no salen	Falta configurar SMTP o sigue activo el modo simulación (`NOTIFICATION_DRY_RUN=true`).

14. Video demostrativo

Hay un recorrido en video de todos los módulos, con datos de demostración ficticios, en **www.tecnoros.ar**, sección Productos propios.

15. Glosario

Término	Significado
CVE / CVSS	Identificador público de una vulnerabilidad / puntaje de gravedad de 0 a 10.
EPSS	Probabilidad estimada de que una vulnerabilidad sea explotada en los próximos días.
CISA KEV	Catálogo de vulnerabilidades que ya se están explotando en ataques reales.
SIEM	Sistema que junta y analiza logs para detectar ataques.
SOAR	Automatización de la respuesta ante incidentes.
Playbook	Receta de pasos automáticos ante un tipo de alerta.
MITRE ATT&CK	Catálogo mundial de técnicas usadas por atacantes.
SLA	Tiempo máximo comprometido para atender un caso.
MFA / SSO	Doble factor de autenticación / inicio de sesión único con la cuenta de la empresa.
Modo simulación (dry-run)	Las acciones se registran pero no se ejecutan sobre la infraestructura real.